COMPUTER LAW & SECURITY REVIEW 35 (2019) 105342

Available online at www.sciencedirect.com

ScienceDirect

journal homepage: www.elsevier.com/locate/CLSR

Computer Law & Security Review

Data Protection Impact Assessment: A tool for accountability and the unclarified concept of 'high risk' in the General Data Protection Regulation

Katerina Demetzou

Faculty of Law and Science Faculty, Radboud University, Nijmegen, the Netherlands

ARTICLE INFO

Keywords:
DPIA
High risk
Data protection
Accountability
Compliance
GDPR
Objective assessment
Connotation

ABSTRACT

Article 35 of the GDPR introduces the legal obligation to perform DPIAs in cases where the processing operations are likely to present high risks to the rights and freedoms of natural persons. This obligation is part of a change of approach in the GDPR towards a modified compliance scheme in terms of a reinforced principle of accountability. The DPIA is a prominent example of this approach given that it has an inclusive, comprehensive and proactive nature. Its importance lies in the fact that it forces data controllers to identify, assess and ultimately manage the high risks to the rights and freedoms. However, what is first and foremost important for a meaningful performance of DPIAs, is to have a common and objective understanding of what constitutes a risk in the field of data protection and of how to assess its likelihood and severity. The legislature has approached these concepts via the method of *denotation*, meaning by giving examples of (highly) risky processing operations. This article suggests a complementary approach, the *connotation* of these concepts and explains the added value of such a method. By way of a case-study the article also demonstrates the importance of performing complete and accurate DPIAs, in terms of contributing to improving the protection of personal data.

© 2019 Katerina Demetzou. Published by Elsevier Ltd. All rights reserved.

1. Introduction

In May 2018 the revised European general legal framework on the protection of personal data, namely the General Data Protection Regulation (hereafter, the GDPR), became applicable. The revision of the preceding legal framework (the Data Protection Directive 95/46) took place in order to provide for a more effective and consistent protection of personal data within a 'dynamic' and 'vulnerable' digital environment.[1] One major change of approach that is apparent in the GDPR is a shift towards accountability, with a view to achieving effective data protection in practice.[2] This approach is materialized through the controller's general obligation to 'implement appropriate technical and organizational measures to ensure and to be able to demonstrate that processing is performed

E-mail address: k.demetzou@cs.ru.nl

[1] Hustinx, P., 'EU Data Protection Law: The Review of Directive 95/46/EC and the Proposed General Data Protection Regulation' in Marise Cremona (ed), *New Technologies and EU Law*, (Oxford University Press 2017), 2.

[2] The EDPS has characterised the introduction of the accountability principle as one of the most remarkable innovations of the GDPR. See, EDPS (European Data Protection Supervisor), 'Opinion 3/2015 (with Addendum) Europe's Big Opportunity - EDPS Recommendations on the EU's Options for data protection reform', 27 July 2015 (updated with addendum, 9 October 2015), 3.

https://doi.org/10.1016/j.clsr.2019.105342
2212-473X/© 2019 Katerina Demetzou. Published by Elsevier Ltd. All rights reserved.

in accordance with this Regulation'[3] and through other specific legal obligations such as data protection by design and by default (hereafter, DpbD),[4] the obligation to perform Data Protection Impact Assessments (hereafter, DPIA),[5] as well as the obligation to appoint a Data Protection Officer (hereafter, DPO).[6,7] The shift towards accountability testifies to the need to 'strengthen the role and the responsibility of data controllers'.[8] What has been highlighted multiple times,[9] is that the existing data protection principles remain valid; what needed to change were the measures and the mechanisms that would guarantee a 'better application of the existing data protection principles in practice'.[10]

In the present article, I will raise the question of whether the newly introduced legal obligation to conduct a DPIA (Article 35 GDPR) will contribute to a reinforced accountability in the context of data protection. I will explain that the DPIA is a mechanism to promote accountability[11] and to thereby strengthen the controller's responsibility – both cornerstone changes of the revision of the data protection legal framework. To that end, Section 2 is a brief presentation of the general accountability principle, where I will argue how and to what extent accountability can be materialized via *inter alia* the obligation to conduct DPIAs. However, this obligation comes with unclarified issues, notably the concept of 'high risk' in data protection. In Section 3, I will investigate this concept, asking the question of how it operates in the legal context of the DPIA, given that it is the concept of 'high risk' that triggers this legal obligation. This will involve an analysis of gaps in terms of meaning and scope of the concept of 'risk', including a proposal how to address these gaps. Lastly, I will investigate whether, and if so how, the correct application of the DPIA helps to achieve an effective[12] and high level of data protection. This will become apparent in Section 4 where I will introduce a Case study to demonstrate how Article 35 shapes the role of the data controller and to what extent this can contribute to an effective data protection. Overall, the aim of the present article is twofold; to show how the correct use and application of the DPIA mechanism will lead to a strengthened accountability for the data controller and thereby a strengthened data protection as well as to propose a way to legally qualify *risk* as a constitutive criterion of the DPIA.

2. Accountability and the legal obligation to perform a DPIA

In this section, I will describe an important change of approach introduced by the legislature in the GDPR, namely *a reinforced accountability principle,* its relationship to the legal obligation to perform DPIAs and the way this new approach has come to shape the role of the data controller.

The data controller is the actor that initiates any processing of personal data and that bears the responsibility to process personal data in accordance with the principles established in EU data protection law. The data protection revision that led to the adoption of the GDPR has introduced changes that mainly touch upon two axes; user empowerment is the first axis, where we see an extension of already existing data subject rights and the addition of new rights.[13,14] The second axis refers to the obligations of the data controller, or as elsewhere termed as the 'real responsibility of responsible organizations'.[15] The legislature seems to be channeling its efforts towards a more meaningful fulfillment of the data controller's obligations, by promoting an *ex ante* focus of regulation[16] and by introducing mechanisms that will contribute to a 'better application of the existing data protection principles in practice'.[17] What the legislature found crucial to reconsider during this revision, was not the data protection principles per se, but the way in which these principles (and their related obligations) should be effectively complied with.

[3] Article 24(1) GDPR.

[4] Article 25 GDPR.

[5] Article 35 GDPR.

[6] Article 37 GDPR.

[7] The appointment of a DPO, the carrying out of DPIAs and implementation of DpbD, have been considered as core measures for ensuring accountability, by the legislature, since the early stages of the data protection reform. See, Commission, Communication from the Commission to the European Parliament, the Council, the Economic and Social Committee and the Committee of the Regions, 'A comprehensive approach on personal data protection in the European Union', COM(2010) 609 final < https://eur-lex.europa.eu/legal-content/en/TXT/?uri=CELEX:52010DC0609>, 12.

[8] Article 29 Data Protection Working Party 'Opinion 3/2010 on the Principle of Accountability', 19. The link between 'accountability' and its potential for enhancing the data controller's responsibility has been mentioned various times, See Commission (n 7), 11, EDPS, Opinion of the EDPS on the Communication from the Commission to the European Parliament, the Council , the Economic and Social Committee and the Committee of Regions – "A comprehensive approach on personal data protection in the European Union", Brussels, 14 January 2011 < https://edps.europa.eu/sites/edp/files/publication/11-01-14_personal_data_protection_en.pdf >, 21,22.

[9] Article 29 Data Protection Working Party WP 168 The Future of Privacy: Joint Contribution to the Consultation of the European Commission on the Legal Framework for the Fundamental Right to Protection of Personal Data, <https://www.garanteprivacy.it/documents/10160/10704/WP168++The+Future+of+PrivacY>, pp. 6, 12. Also see, Commission (n 7), Commission, Communication from the Commission to the European Parliament and the Council, 'Stronger Protection, New Opportunities - Commission Guidance on the Direct Application of the General Data Protection Regulation as of 25 May 2018', COM(2018) 43 final < https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A52018DC0043>, 11 , EDPS (n 8), 8.

[10] Article 29 Working Party (n 9), 6.

[11] The Commission has explicitly characterised the legal obligation to conduct a DPIA as a 'scalable obligation depending on risk' and has acknowledged it as a measure that implements the principle of accountability. See, Commission (n 9), 3.

[12] Effective protection is not only the legislature's quest. It also derives from the nature of data protection as a fundamental right. See EDPS (n 8), 8. Also see, Article 29 Working Party (n 9), 7 '*the new framework should have as main goal effectiveness and effective protection of individuals*'.

[13] Hustinx (n 1), 31.

[14] For example, the right to information has been enhanced, there is a new right to data portability, and the right to be forgotten.

[15] Hustinx (n 1), 32.

[16] Koops, BJ, (2014) The Trouble with European Data Protection Law, *International Data Privacy Law*, Volume 4, Issue 4, p 250–261, https://doi.org/10.1093/idpl/ipu023.

[17] Article 29 Working Party (n 9), 6.

The strengthening of the data controller's responsibility as well as the mechanisms that could lead to such strengthening, have been key points of the discussion[18] since the beginning of the data protection framework revision.

2.1. *Article 5(2) GDPR: a general accountability principle*

Technological development and the subsequent increase of the risks for individuals' privacy and data protection[19] is one of the main challenges for effective data protection and therefore a major reason why the revision of the DPD began in the first place. One of the identified problems with regard to the previous data protection legal framework was the fact that it established a *reactive approach* to privacy and data protection which led to 'poor compliance practices and data losses as recurring problems'.[20] The way the reality was being formed, challenged the effectiveness of the preceding legal framework on data protection (DPD); the downsides of the DPD,[21] had to be taken into account by the legislature, when deciding on the approach to be embedded in the new legal framework (the GDPR).

A major shift[22] in data protection law, which is indicative of the legislature's intention to 'reaffirm and strengthen the data controller's responsibility towards the processing of personal data',[23] is the reinforcement of the 'accountability principle' in Article 5(2) GDPR.[24] According to Article 5(2), the controller shall be responsible for 'ensuring compliance' and shall be able to 'demonstrate compliance' with data protection principles in practice; it has to do with being answerable for actions, decisions and performance.[25] The legislature does not 'aim at subjecting data controllers to new principles, but rather at ensuring de facto effective compliance with existing ones'.[26] Its emphasis is on showing how responsibility is exercised and making this verifiable. Accountability was also embraced and promoted by the WP29[27] as a way to 'strengthen the role of the data controller and increase his responsibility'.[28] In another opinion, the WP29 upheld the principle of accountability by stating that 'controllers should always be accountable for compliance with data protection obligations including demonstrating compliance regarding any data processing whatever the nature, scope, context, purposes of the processing and the risks for data subjects are'.[29]

Accountability is not a novel concept in data protection law. It first appeared as a basic data protection principle in the OECD Guidelines[30] ('A data controller should be accountable for complying with measures which give effect to the principles stated above'), back in 1980.[31] Directive 95/46 implied this principle in Article 6(2) which stipulated that 'It shall be for the controller to ensure that paragraph 1 is complied with.' However, as noted by the EDPS,[32] the scope of this provision was limited. The way in which the legislature chose to materialize the accountability principle in the GDPR testifies to its intention to 'stimulate controllers to put into place proactive measures in order to be able to comply with all the elements of data protection law'.[33] An important point to make is that this major shift is not just about the explicit reference to the actual term 'accountability'. What matters is the essence of the concept and the way in which this essence comes into life through specific provisions in the GDPR.[34] Besides, in various data protection regulations 'many substantive provisions were in fact designed to enable accountability'[35] even if an explicit reference to the principle was missing. The shift in the GDPR is about the way that the legislature has chosen to set up a modified compliance scheme by *inter alia* materializing the accountability principle via a general obligation in Article 24 and via more specific obligations (e.g., DPOs, DPIAs, Privacy by design) all of which have a common characteristic; they all suggest specific measures and mechanisms which establish a proactive approach,[36] facilitate the implementation of accountability and therefore enable compliance and its demonstration thereof. They do not add any new principles; instead,

[18] Commission (n 7), Article 29 Working Party (n 9), EDPS (n 8).
[19] Article 29 Working Party (n 9), 12.
[20] EDPS (n 8), para 99.
[21] Article 29 Working Party (n 8) para 2.: *"the present legal framework has not been fully successful in ensuring that data protection requirements translate into effective mechanisms that deliver real protection"*.
[22] Hustinx (n 1), 46, Kuner, C., 'The European Commission's Proposed Data Protection Regulation: A Copernican Revolution in European Data Protection Law' Bloomberg BNA Privacy and Security Law Report, p 1-15, <https://ssrn.com/abstract=2162781>.
[23] Article 29 Working Party (n 8), 8.
[24] Article 5(2) GDPR stipulates that 'The controller shall be responsible for, and be able to demonstrate compliance with, paragraph 1 ('accountability')'.
[25] EDPS, 'Accountability on the Ground: Guidance on Documenting Processing Operations for EU Institutions, Bodies and Agencies', 9 February 2018 <https://edps.europa.eu/data-protection/our-work/publications/guidelines/accountability-ground-provisional-guidance_en>, 4.
[26] Article 29 Working Party (n 8), 10.
[27] The WP29 (Article 29 Working Party) was an advisory body which has now been replaced by the EDPB (European Data Protection Board). The EDPB is composed of representatives of the national supervisory authorities, and the European Data Protection Supervisor (EDPS). It is an independent EU body, which contributes to the consistent application of data protection rules throughout the European Union, and promotes cooperation between the EU's supervisory authorities. (https://edpb.europa.eu/about-edpb/about-edpb_en).
[28] Article 29 Working Party (n 8).
[29] Article 29 Data Protection Working Party 'Statement on the role of a risk-based approach in data protection legal frameworks.' Tech. Rep. WP 218 (30 May 2014), 3.
[30] OECD Guidelines on the Protection of Privacy and Transborder Flows of Personal Data, 1980 <http://www.oecd.org/sti/ieconomy/oecdguidelinesontheprotectionofprivacyandtransborderflowsofpersonaldata.htm>.
[31] The OECD Guidelines were revised in 2013 (See OECD, The OECD Privacy Framework (2013) <http://www.oecd.org/sti/ieconomy/oecd_privacy_framework.pdf>) For a more detailed analysis on the origins and development of the accountability principle in data protection see Alhadeff J, Van Alsenoy B., Dumortier J., (2012) The Accountability Principle in Data Protection Regulation: Origin, Development and Future Directions, in Guagnin D., Hempel L., Ilten C., Kroener I., Neyland D., Postigo H. (eds), Managing Privacy through Accountability, Palgrave Macmillan, London <https://doi.org/10.1057/9781137032225_4>.
[32] EDPS (n 8), para 102.
[33] EDPS (n 8), para 102.
[34] Article 29 Working Party (n 8), para 23.
[35] Alhadeff, Van Alsenoy and Dumortier (n 31), 6.
[36] Alhadeff, Van Alsenoy and Dumortier (n 31), 27.

they serve as mechanisms for the effective implementation of the already existing data protection principles.[37] Accountability has been characterised as a 'fundamental principle of compliance'[38] and as a 'means to address compliance challenges posed by emerging technologies and business models'.[39]

2.2. *Article 35: the legal obligation to perform a DPIA*

After having briefly discussed the reasoning behind the principle of accountability, its goals and the means for achieving these goals, I shall now turn to the legal obligation of performing DPIAs. The DPIA has been suggested numerous times as a measure for the implementation of the accountability principle.[40]

Article 35 of the GDPR lays down the legal obligation of data controllers to perform a DPIA 'where a type of processing in particular using new technologies, and taking into account the nature, scope, context and purposes of the processing, is likely to result in a high risk to the rights and freedoms of natural persons'. Thus, the controller has to first of all identify risks that the processing activities might present, assess these risks and in case they are evaluated as 'high', mitigate them in order to bring them to an acceptable level. The WP29 in its guidelines on DPIAs provides for the following definition: 'DPIA is a process to describe the processing, assess its necessity and proportionality and help manage the risks to the rights and freedoms of natural persons resulting from the processing of personal data by assessing them and determining the measures to address them […] In other words the DPIA is a process for building and demonstrating accountability'.[41]

The importance of performing this process lies, primarily, in the fact that it is an inclusive and comprehensive procedure which forces the controller to take into account all the principles and obligations under the data protection legal framework, in the very early development stage of a service or a product. The DPIA has a proactive nature,[42] which means that data protection is taken into account *ex ante* and not *ex post* after a harmful event has taken place. Therefore, if risks have been properly identified and assessed, the data controller has to mitigate them through appropriate technical and organizational measures and lower them to levels that are acceptable as defined by the essence and the scope of the relevant rights and freedoms. In case 'the data controller cannot find sufficient measures to reduce the risks to an acceptable level (i.e., the residual risks are still high)',[43] the data controller has to consult with the Data Protection Authority, following a procedure described in Article 36 of the GDPR.

What we realize, is that the DPIA is a mechanism entirely aligned with the rationale behind the principle of accountability. It is a legal obligation that frames the already existing obligations (i.e., compliance with the data protection principles, documentation of processing operations, technical and organizational measures in place etc.) under a more effective compliance scheme based on the criterion of 'high risk'. Having said that, a meaningful and effective performance of a DPIA requires a clear understanding of what the 'high risk' criterion means. In the following section, I will discuss the 'high risk' criterion and I intend to demonstrate the way in which this concept should be legally qualified under the GDPR.

3. The concept of *risk*

3.1. *Data processing: a risky endeavor per se*

When talking about *risk* in data protection one should begin from the premise that data processing is by default an activity that raises risks. This is the reason why a right to data protection was introduced in the first place; 'data protection is first and foremost a legal framework for the regulation of the risks stemming from the development of computers'.[44] As mentioned in the previous section,[45] the goal of the general accountability principle is to achieve effective compliance with data protection rules, in the light of new and increased risks raised by new technologies. Therefore, technologies involved in data processing activities have always been raising risks, against which the legislature has always been reacting (either by introducing a new right –the right to data protection-, or by reframing the approach –as is the case of the GDPR- in terms of more effective protection of that right). Some legal scholars have also acknowledged the inherent risks in data processing operations.[46]

In the GDPR, the legislature accentuates this premise by stipulating in Article 24 that the technical and organizational measures taken by the controller should be dependent on the 'nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons'.[47] The legislature introduces *risk* as a criterion for 'the determination of the concrete measures

[37] Article 29 Working Party (n 9), 2,6 and Alhadeff, Van Alsenoy and Dumortier (n 31), 27.

[38] Alhadeff, Van Alsenoy and Dumortier (n 31), 19.

[39] Alhadeff, Van Alsenoy and Dumortier (n 31), 14.

[40] Article 29 Data Protection Working Party, 'Guidelines on Data Protection Impact Assessment (DPIA) and Determining Whether Processing Is "Likely to Result in a High Risk" for the Purposes of Regulation 2016/679' WP 248 rev 0.1 (4 April 2017), as last revised and adopted on 4 October: 'it is characterised as a process for building and demonstrating accountability'. See also, Article 29 Working Party (n 9) paras 77–79, Commission (n 7), 12, Commission (n 9), 3, EDPS (n 8) paras 101–107 and Article 29 Working Party (n 8) para 42.

[41] Article 29 Working Party (n 40). This was also included in the Commission's proposal of 2012 for a GDPR (art.22(2)).

[42] Article 29 Working Party (n 9), 20.

[43] Article 29 Working Party (n 40), 19.

[44] Gellert, R, 'Understanding data protection as risk regulation' (2015) Internet J. Law 18(11), 3.

[45] Section 2.1. "Article 5(2) GDPR: A general accountability principle."

[46] Hustinx (n 1), 38 "Indeed it should be taken into account that risk is inherent to any data processing", Lynskey, O, The Foundations of EU Data Protection Law, Oxford University Press 2015, ISBN: 9780198718239, "many of the intangible harms are caused by the very act of data processing whether or not the personal data processed is misused in any way", 11.

[47] Also Recital 74 GDRP mentions that measures of controllers should take into account the risk to the rights and freedoms of natural persons.

to be applied'.[48] This is a choice that adds scalability when it comes to compliance, in the sense that the scope of the legal duties of data controllers depends on the risk posed by their processing operations,[49] and more specifically the *likelihood and severity* of that risk. Scalability is inextricably linked to the principle of accountability,[50,51] in that the latter is 'implemented through scalable obligations'.[52] Not all data processing operations present the same level and/or magnitude of risks, therefore the data controller shall not be obliged to take the exact same measures under all circumstances so as to comply with the data protection principles that safeguard the essence of the right to data protection. According to the WP29, 'a one-size-fits-all approach would only force data controllers into structures that are unfitting and ultimately fail'.[53] The introduction of the legal obligation to perform a DPIA, under Article 35, is a prominent example of the approach described above. Under this obligation, the data controller may be held liable for the fact that they did not appropriately assess and manage the *high risk(s)* presented by the processing operations.

3.2. *'High risk' in the DPIA*

The legal condition that is constitutive of the obligation to perform a DPIA is the requirement of *'high risk'*. It is constitutive in the sense that in case it is not likely that the processing operations will result in *high risk to the rights and freedoms* of natural persons, then there is no legal obligation on the part of the data controller to perform a DPIA.

The concept of *risk* and its meaning in the context of data protection has gained much attention by legal scholars.[54,55] This is justified because, as illustrated above, *risk* is a crucial criterion introduced in order that measures are scaled and tailored by data controllers, according to the specific data processing circumstances.[56] It is also because the methodological approach of *risk* in data protection constitutes a 'novelty'.[57] As van Dijk et al.[58] have correctly pointed out, this novelty lies primarily in the fact that *risk* in data protection should be assessed in the broader context of 'rights and freedoms of data subjects' and secondly in that it is 'methodologically coupl[ed] [with] risk management instruments'. It is therefore important to have a clear understanding of what constitutes a risk within the European general legal framework on data protection (GDPR).

In the case of the DPIA, the processing operations should be *likely to result in a **high** risk* in order for this legal obligation to be triggered. The attribute 'high', indicates qualities (i.e., (high) likelihood and/or (high) severity) that are by definition inherent to the notion of risk. According to the WP29 'A risk is a scenario describing an event and its consequences, estimated in terms of severity and likelihood'.[59] The fact that consideration should be given to both *likelihood* and *severity* is also mentioned in Recitals 75 and 76 of the GDPR.[60] Thus, in order for the data controller to reach the conclusion that something could constitute a risk (either high or low) they need to first assess if and how severe the risk will be and if and how likely it is that this event will occur. If this assessment leads to a conclusion that it is likely that high risk will occur, then the data controller is obliged to perform a DPIA, with the purpose of mitigating the identified high risk.

Therefore, identifying what constitutes a risk in data protection is not enough. What is also crucial, is to have a common approach as to the way the data controller should assess *severity* and *likelihood*. This triple assessment (first assessment relates to 'what constitutes a risk', and the second and third assessments refer to whether this risk is 'high' - in terms of likelihood and severity accordingly) is an 'assessment of a hypothetical event'.[61]

The legislature requires that the afore-mentioned triple assessment is *objective*.[62] It is important to understand what 'objective assessment' means and in which ways objectivity could be achieved when data controllers assess hypothetical risks, their likelihood and their severity. What is actually the desideratum here, is that data controllers perform risk assessments in a way that the conclusions they draw are reliable, verifiable, trustworthy and contestable. Therefore, what is needed is the use of language and means that those involved in the field of data protection share and understand. That said, a computer scientist and a lawyer do not share the

[48] Article 29 Working Party (n 8), 2.

[49] Article 29 Working Party (n 29), Quelle, C, (2015) Does the Risk-Based Approach to Data Protection Conflict with the Protection of Fundamental Rights on a Conceptual Level?, < https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2726073> , Gellert, R., 'Understanding the Notion of Risk in the General Data Protection Regulation' (2018) Volume 34, Issue 2, Computer Law & Security Review, 279-288, < https://doi.org/10.1016/j.clsr.2017.12.003.>.

[50] Article 29 Working Party (n 8).

[51] This has also been upheld by the EDPS (n 8) para 104.

[52] Commission (n 9) 3.

[53] Article 29 Working Party (n 8) para 45.

[54] Gellert (n 49).

[55] Although it seems that official bodies have not engaged in a deep debate with regard to the notion of risk per se, but have limited themselves to debates concerning the risk-based approach (Gellert (n 49), 2).

[56] Article 29 Working Party (n 8) para 46.

[57] van Dijk, N., Gellert, R. and Rommetveit, K. 'A Risk to a Right: Beyond Data Protection Risk Assessments' (2016) Volume 32, Issue 2, Computer Law & Security Review, 286-306, https://doi.org/10.1016/j.clsr.2015.12.017., 3.

[58] van Dijk, N., Gellert, R. and Rommetveit, K. 'A Risk to a Right: Beyond Data Protection Risk Assessments' (2016) Volume 32, Issue 2, Computer Law & Security Review, 286-306, https://doi.org/10.1016/j.clsr.2015.12.017., 3.

[59] Article 29 Working Party (n 40), 6, Article 29 Data Protection Working Party, 'Opinion 05/2014 on Anonymisation Techniques', 7 "severity and likelihood of this risk should be assessed".

[60] Recital 75 GDPR "The risk to the rights and freedoms of natural persons, of varying likelihood and severity [...]",Recital 76 GDPR "The likelihood and severity of the risk to the rights and freedoms of the data subject [...]".

[61] Article 29 Data Protection Working Party, 'Guidelines on Personal Data Breach Notification under Regulation 2016/679′ (Wp250rev.01), as last revised and adopted on 6 February 2018', 24 : Contrary to the assessment in case a personal data breach occurs, whereby the controller should again assess whether the breach that occurred is likely to result in high risk to the rights and freedoms of the natural persons. (Article 34 GDPR).

[62] Recital 76 GDPR "Risk should be evaluated on the basis of an objective assessment; by which it is established whether data processing operations involve a risk or a high risk".

same understanding as to the notion of risk. Thus, if a computer scientist makes a claim about if and how risky processing operations are, the judge, will encounter difficulties in verifying the truthfulness of that claim and evaluating it in legal terms. Even if the legislature had not explicitly mentioned the objectivity requirement, it would still implicitly emerge as a desideratum given the choice of the legal instrument of Regulation (instead of a Directive) and its underpinning aim for a harmonized and of high level data protection.[63] Risk assessment includes multiple normative decisions[64] that should be made by the data controller. The lack of objective and shared legal criteria on the way these decisions should be made, could lead to a variety of approaches towards this triple assessment, dependent on the particularities of each Member State in terms of culture and tradition. The following question is raised: does the GDPR provide for such criteria? In the next section I will answer this question and I will give a comprehensive overview of the guidance given by the legislature.

3.3. *Legislature's guidelines*

Despite its importance, both in terms of forming obligations under the GDPR and in terms of triggering legal obligations (e.g., DPIA (art 35), communication of personal data breach to the data subject (art 34)), there is no common understanding of the legal concept of *risk* in EU data protection law.[65] The legislature limits itself to offering guidance on what could possibly/likely constitute '(highly)risky'[66,67] data processing operations but refrains from providing ways and criteria on how the above mentioned objective triple assessment should be performed[68] and later on judged and evaluated.

The GDPR guides data controllers with regard to the types of data processing operations that are likely to present (high) risks. More specifically, Recital 75 presents in a non-exhaustive way ('in particular'), types of data processing operations that 'may' result in '**risk** to the rights and freedoms of natural persons, of varying likelihood and severity'. These types could be grouped under two major categories based on two criteria: the unwanted result (damage – physical, material or non-material) and the purpose, nature, scope of the processing. The first category refers to damage that might arise because of the data processing activity *(risk to discrimination, identity theft or fraud, financial loss, damage to the reputation, loss of confidentiality of personal data protected by professional secrecy, unauthorised reversal of pseudonimisation or any other significant economic or social disadvantage)* as well as to a (more general) result that is unwanted, and that is the deprival of 'their rights and freedoms' or the prevention from 'exercising control over their personal data'. The second category refers to the purpose *(evaluation of personal aspects for profiling purposes)*, scope *(processing of large amounts of data)* and nature *(processing of sensitive data, processing of data of vulnerable natural persons)* of the processing. This category does not refer to damage but classifies processing activities as (possibly) risky because of their purpose, scope or nature. The criteria of Recital 75 (unwanted result, purpose, nature, scope of processing) should be taken into account when deciding upon (highly) risky processing operations.

Recitals 89 and 91 along with Article 35(3) go one step further and provide for indicative/non-exhaustive ("in particular") lists of processing operations that are by default considered likely to present **high** risks. The following examples are provided:

(a) Processing operations that involve the 'use of new technologies' [Rec 89, art 35(1)]
(b) systematic and extensive evaluation of personal aspects relating to natural persons which is based on automated processing, including profiling, and on which decisions are based that produce legal effects concerning the natural person or similarly significantly affect the natural person [Rec 91, art 35(3)];
(c) personal data are processed for taking decisions regarding specific natural persons following the processing of special categories of personal data, biometric data, or data on criminal convictions and offences or related security measures [Rec 91];
(d) processing on a large scale of special categories of data referred to in Article 9(1), or of personal data relating to criminal convictions and offences referred to in Article 10 [Art 35(3)]; or
(e) systematic monitoring of a publicly accessible area on a large scale [Rec 91, Art 35(3)];
(f) processing operations that prevent data subjects from exercising a right or using a service or a contract [Rec 91];
(g) processing operations that render it more difficult for data subjects to exercise their rights [Rec 91].

The above mentioned types of processing operations are flagged by the legislature as 'likely' to raise risks or high risks. They help controllers answer the question of whether a specific processing is of a type 'likely to result in a high risk'. On top of these processing operations enumerated in the GDPR, Article 35(4) requires that national Data Protection Authorities (DPAs) also establish lists 'of the kind of processing operations which are subject to the requirement for a data protection impact assessment'. The WP29 has already proceeded to such an endeavor by enlisting nine criteria – indicators of *high risk* processing operations.[69] At the time of writing of the article,

[63] Recital 4 GDPR "The processing of personal data should be designed to serve mankind.", Recital 10 GDPR "In order to ensure a consistent and high level of protection of natural persons […]".

[64] Quelle, C. 'The Data Protection Impact Assessment: What Can It Contribute to Data Protection?' (LLM Thesis, Tilburg University, 2015), available at <arno.uvt.nl/show.cgi?fid=139503>, 108.

[65] CIPL (Centre for Information Policy Leadership, Hunton & Williams LLP), 'Risk, High Risk, Risk Assessments and Data Protection Impact Assessments under the GDPR', CIPL GDPR Interpretation and Implementation Project, 21 December 2016, 13.

[66] CIPL (n 65).

[67] In the words of Article 35, types of processing operations 'likely to result in a high risk to the rights and freedoms of natural persons'.

[68] According to Gellert (n 49), 2: "ultimately the way risk is defined in the GDPR is somewhat irrelevant: what matters most is the methodology used and the type of risk at work therein".

[69] Article 29 Working Party (n 40), 6, Among which: matching or combining datasets, vulnerable data subjects, processing that prevents data subjects from exercising a right or using a service or a contract etc.

some national DPAs have already published their 'blacklists' and 'whitelists' and the EDPB[70] has issued opinions on 30 draft national DPIA lists.[71]

The guidance provided by the legislature and by the European and national regulators serves the so called 'high-level screening test'.[72] This is a test that indicates processing operations which present 'a reasonable chance [they] may be high risk and so a DPIA is required to assess the level of risk in more detail'[73] but which does not affect the controller's overriding obligation to assess any proposed processing operation against the requirement to perform DPIAs. The ICO has clarified that the phrase 'likely to result in a high risk' actually indicates the need to perform such a 'high-level screening test' by examining whether there are 'features which point to the potential for high risk'.[74] In practice, the data controller needs to 'screen for any red flags which indicate that [they] need to do a DPIA to look at the risk (including the likelihood and severity of potential harm) in more detail'.[75] The wording 'reasonable chance' suggests that there is also a chance that processing operations which present features that point to the potential for *high risk* do not –under specific circumstances- present *high risk(s)*. Having said that, let us look into some more specific scenarios which prove that it is insufficient to rely only on the legislature's guidelines when talking about *(high) risk* as a legal requirement in the GDPR.

> [A] On the level of the ***'threshold analysis'*** (or as mentioned before, the 'high-level screening' test) whereby the data controller decides whether the processing operations meet the 'high risk' criterion and therefore fall (or do not fall) under the legal obligation of Art 35;

Case A.1: the processing operation does fall under one (or more) of the 'red flags' (therefore the 'likely to result in a high risk' threshold is met) but the data controller decides not to perform a DPIA because under the specific circumstances, the processing is unlikely to result in a high risk. The ICO has discussed this possibility explaining that in such a case the data controller has to justify their choice not to perform a DPIA and document the reasons why in a particular context the risk is neither (highly) likely nor (highly) severe.

Case A.2: the processing operation does not fall under any of the 'red flags', but proves later on (e.g., after a harmful situation has occurred) that there were high risks that had not been identified or had been identified but incorrectly assessed as low/medium, and therefore a DPIA had not been performed.

In both A.1, A.2 the data controller decides not to conform to the legal obligation of Art 35. The data controller needs to be able to objectively assess the risks in order to substantially explain and justify the choice of not performing a DPIA. Otherwise, they run the risk to receive fines for having infringed the law on two grounds; firstly, for not having been able to explain and justify why they considered that the risks were not high, even though the processing operations are under the legislature's 'red flags' (in A.1) and secondly, for having performed the threshold analysis in a wrong way (in A.2). In both cases, the guidance provided by the legislature is not enough. What is needed, is guidance as to the tools and criteria that should be used by the data controller in order to objectively assess the risks.

> [B] On the level of the ***'risk assessment and management'*** as part of actually performing a DPIA, whereby the data controller –having passed the threshold analysis test- has decided that the legal obligation of Art 35 is applicable;

Case B.1: the data controller has improperly assessed the identified risks and as a result has improperly managed them, meaning that the risks have not been reduced to an acceptable level.

Case B.2: due to the incorrect risk assessment performed, the data controller did not manage to identify the residual risks that remain high and therefore did not meet their legal obligation to consult the DPA prior to processing, under Art 36.

In both B.1, B.2 the data controller performs the DPIA; they meet the legal obligation of Art 35, but they meet it in an improper way (B.1) something that could result in them not acknowledging that they also have to conform to the legal obligation of Art 36 (B.2). Both cases result from the fact that the data controller performed the DPIA in an incorrect way because they have been given no explicit rules or criteria for the examination of the likelihood and severity of an identified risk.

In a nutshell, on the level of the 'threshold analysis' the guidelines provided by the legislature, only partly cover the needs of data controllers. There can be cases whereby data controllers remain exposed to high fines due to the lack of guidance (see above, cases A.1., A.2). On the level of the actual performance of a DPIA, the guidelines prove insufficient to assist data controllers in objectively measuring the identified risks. This becomes even more important given that based on this objective assessment, subsequent decisions, that have legal implications, are made (e.g., decisions on the most appropriate measures in order to manage the risks, decisions with regard to the acceptability of residual risks, decisions on whether prior consultation is needed).

3.4. *Evaluating the legislature's approach*

As said, the European legislature has made a choice to refer in the GDPR to specific scenarios (data processing operations) which are qualified as *risky* (Rec. 75, 91 and Art. 35(3)) or as *highly risky* (Rec. 91, Art. 35(3)). The European and national regulators have done the same. The chosen method is called

[70] The European Data Protection Board (EDPB) is an independent European body, which contributes to the consistent application of data protection rules throughout the European Union, and promotes cooperation between the EU's data protection authorities. See for more information, https://edpb.europa.eu/edpb_en.

[71] EDPB (European Data Protection Board), Opinions on the draft lists of the competent supervisory authorities regarding the processing operations subject to the requirement of a data protection impact assessment (Article 35.4 GDPR) https://edpb.europa.eu/our-work-tools/consistency-findings/opinions_en.

[72] ICO, 'When do we need to do a DPIA'? https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/data-protection-impact-assessments-dpias/when-do-we-need-to-do-a-dpia/.

[73] ICO (n 72).

[74] ICO (n 72).

[75] ICO (n 72).

denotation (extension) of the concept of *risk*, meaning that the legislature provides for examples of objects referred to by the word[76] (e.g., Recital 75 refers to the *risk of discrimination, identity theft or fraud, evaluation of personal aspects for profiling purposes etc.* Likewise, Article 35(3) provides examples of 'high risk' processing activities). However, if we take into account that *risk* is, by definition, assessed in terms of 'likelihood and severity', and even further, that *risk* as a legal condition for the DPIA obligation should be 'high', this approach seems problematic (as it proved to be the case in Cases A.1, A.2, B.1, B.2 described above). Even if a type of processing operations is given as an example of 'high risk' operation by the legislature, is it always the case that either likelihood or severity or both are high? To reach such a conclusion there are previous steps to be taken which entail an assessment of these qualities. This process could also lead to the conclusion that specific processing operations that have been categorized by the legislature as highly risky, do not present any high risks to the rights and freedoms of natural persons in a particular context (as was in Case A.1).

Although, as will be explained below, introducing open-ended notions is desirable, it is the case that under the GDPR, data controllers are left with a wide margin of discretion as to determining whether a risk is high for rights and freedoms, and as to the means used for such an assessment. This would leave them exposed to becoming liable for not correctly assessing the risks and would also be a peril for a harmonized and effective protection of personal data.[77] We shall not forget that the main purpose of having in place the legal instrument of a Regulation is to have a high and consistent[78] level of data protection for natural persons throughout the Union. For that, it is important to give these terms an autonomous meaning within the specific context of data protection.

Although the legislature's approach to concepts such as *risk, likelihood, severity* raises questions as to how these concepts can be operationalized, it is neither unjustified nor wrong. The legislature uses a more open language and does not provide for exhaustive definitions or criteria of the afore mentioned concepts. This approach is, first and foremost, in line with the principle of accountability.[79]According to the WP29 Opinion on accountability, 'the need for scalability and hence flexibility supports the use of open language'.[80] Secondly, the use of broad terms promotes the technologically-neutral character of the GDPR. A technologically-neutral character of data protection legislation is something encouraged by the EDPS,[81] the WP29[82] but most importantly by the legislature, which explicitly refers to the term 'technologically neutral' protection, in Recital 15 GDPR.[83] One objective of framing the law in a technologically-neutral way is 'sustainability'.[84] The legislature should reach a level of abstraction such that new technologies can be covered by the existing piece of legislation. Sustainability that should come from technologically-neutral laws, could and should enhance legal certainty, given that 'legislation does not require continuous adaptation to emerging technologies'.[85]

Legal certainty[86] is an equally important element to be ensured along with scalability, flexibility and technological-neutrality. In Recital 11, the legislature considers the 'setting out in detail of obligations' as an important prerequisite for achieving effective protection of personal data. It seems that we are facing a tension between the quest for scalability, flexibility and technological-neutrality on the one hand and legal certainty on the other hand. This tension is also pointed out by the WP29 which has explicitly acknowledged that it will not be resolved by the Directive itself (now, by the GDPR) but by the Commission or the WP29 that will both give guidance on how open-ended notions and terms are to be interpreted.

3.5. *An additional approach to qualifying risk*

Alongside the legislature's choice to provide examples of processing operations that may raise *risks* and *high risks*, there is another approach that should be added in order to illustrate what (high) risk means under the GDPR. The aim is to qualify the concept of *risk* (and to objectively assess its constitutive qualities: likelihood and severity), in order to enhance legal certainty, to guarantee a high and consistent level of data protection across the Union and to provide common tools and criteria for objective assessment. With this additional approach, my intention is to complement and not replace the legislature's approach.

This additional approach is called *connotation (intension)*. In logic, the connotation of a word is a list of attributes/qualities shared by all members of the class named by the word.[87] If

[76] William Kneale and Martha Kneale, *The Development of Logic* (Clarendon Press 1962).

[77] Kloza, D. and others, 'Data Protection Impact Assessments in the European Union: Complementing the New Legal Framework towards a More Robust Protection of Individuals' d.pia.lab Policy Brief No. 1/2017.

[78] Recital 13 GDPR.

[79] As already mentioned in the previous section, the obligation to perform DPIAs is a specific obligation that materializes the accountability principle and should be interpreted based on the latter. Also 'risk' is a prominent criterion used to provide scalability and flexibility as mentioned in the first part of this section.

[80] Article 29 Working Party (n 8) para 49.

[81] EDPS (n 8) para 38.

[82] Article 29 Working Party (n 9), 12.

[83] Recital 15 GDPR: "In order to prevent creating a serious risk of circumvention, the protection of natural persons should be technologically neutral and should not depend on the techniques used. […]".

[84] Hildebrandt, M. and Tielemans, L. 'Data Protection by Design and Technology Neutral Law' Computer Law & Security Review 19 (2013), 509-521 http://www.sciencedirect.com/science/article/pii/S0267364913001313. According to the authors sustainability along with compensation and innovation are three major objectives of tech neutral legislation. See also Bert-Jaap Koops, 'Should ICT Regulation Be Technology-Neutral?' In Bert-Jaap Koops, Miriam Lips, Corien Prins & Maurice Schellekens (eds) Starting Points for ICT Regulation. Deconstructing Prevalent Policy One-liners, IT &Law Series, Vol. 9, pp. 77-108, The Hague: T.M.C. Asser Press, 2006.

[85] Hildebrandt and Tielemans (n 84) 515.

[86] As Trimidas has pointed out *"the general principles continue to have a value as underlying principles of the constitution which influence the interpretation and application of the law and provide yardsticks for determining the validity of legislation. This applies for example to the principle of protection of legitimate expectations, and the principle of legal certainty"*, Tridimas, PT, Fundamental Rights, General Principles of EU Law, and the Charter. in *Cambridge Yearbook of European Legal Studies*. vol. 17, Cambridge University Press, Cambridge, 2015.

[87] Kneale and Kneale (n 76).

the legislature had adopted the approach of *connotation*, that would mean that it would have provided for the intrinsic elements which qualify the concept of *risk* in the context of the GDPR. The legal qualification of *risk* in relation to data protection and the provision of objective legal criteria against which *likelihood and severity* will be measured, will allow data controllers to examine each processing activity and reach reliable and contestable conclusions as to the (high) risk presented. In her work on conceptualizing the notion of 'essence' of fundamental rights, Brkan makes the point that what is needed, is to elaborate the 'defining features of the concept of essence'.[88] To further substantiate this point, Brkan quotes Raz who has supported the idea that the explanation of a concept 'consists of setting out some of its necessary features'.[89] In the following paragraphs I will point out the legal sources that will provide us with such necessary features and with the appropriate tools in order to be able to identify such features.

To begin with, data protection is an autonomous fundamental right found in Article 8 of the Charter of Fundamental Rights of the EU (CFR). It is a non-absolute, qualified[90] fundamental right that 'must be considered in relation to its function in society'.[91][92] The fact that the concept of *risk* is to be understood with regard to rights that are fundamental in nature (risk to the 'rights and freedoms of natural persons') leads us to the fundamental rights literature and jurisprudence. One shall not disregard the significant body of case law produced by both the CJEU and the ECtHR with regard to the fundamental right to privacy and the fundamental right to data protection. This case law should serve as a source of objectivity when approaching concepts such as *risk, likelihood, severity.*

To give an example, in a 2016 judgment on the Breyer case, there appear instances of relevant terminology; the CJEU refers to the 'risk of identification' and uses words such as 'mere possibility'[93] and 'insignificant risk'.[94] The reasoning that is used by the Court in this case in order to conclude on whether the *risk of identification* was in that specific context 'insignificant', is highly important for identifying legal tools that will be used to assess the *severity* of a risk. The Court, by upholding the AG Opinion, rules that in a case where it is legally or practically impossible for the risk of identification to materialize, then the risk is considered to be insignificant and does not even qualify to go under the protective scope of the Directive (95/46).[95] By referring in this same case to a 'mere possibility' of the risk being materialized, the Court's reasoning adds elements to our understanding of the quality of 'likelihood'. The Court takes a more subjective approach when assessing the *likelihood* requirement, and rules that a mere possibility in abstract would not be sufficient to qualify the risk of identification as highly likely to materialize. This case was dealt by the CJEU and appeared after the GDPR had come into force. That could lead us think that the Court has already started making steps towards giving legal significance to notions that relate to *risk* and its constitutive qualities.

However, up until now the CJEU has been reluctant in using these concepts. Therefore, it is of value to turn towards notions that are relevant to *risk* and that have extensively been dealt with by the Courts. 'Interference', 'violation', 'infringement', 'harm' are prominent examples of legally defined notions that, just as *risk*, reveal a tension between processing operations and the right to data protection.[96] Interpretation of these concepts is primarily based on the acknowledgement that fundamental rights have a specific structure. Qualified fundamental rights comprise of a 'core', or as otherwise termed in the Charter 'essence'[97] and a 'periphery'/ 'penumbra'.[98] However, as legal scholars have pointed out,[99] the boundaries between the essence and the periphery have still not been clearly drawn by the jurisprudence. Any interference with a fundamental right either justified (proportionate) or unjustified (disproportionate) can take place in the 'periphery' and can be classified (e.g., 'serious interference', 'particularly serious interference').[100] On the contrary, the 'essence' of a fundamental right shall not be interfered with, because that

[88] Brkan M. (2018), 'The Concept of Essence of Fundamental Rights in the EU Legal Order: Peeling the Onion to its Core', *European Constitutional Law Review*, 14(2), 332-368. doi:10.1017/S1574019618000159, 349.

[89] Raz J., 'Two Views of the Nature of the Theory of Law. A Partial Comparison', in J.L. Coleman (ed.), *Hart's Postscript. Essays on the Postscript to The Concept of Law* (Oxford University Press 2001), 8.

[90] Or otherwise termed, 'relative fundamental right'. In Barak A, Proportionality: Constitutional rights and their limitations, (Cambridge Studies in Constitutional Law) Cambridge University Press, 2012, doi:10.1017/CBO9781139035293, 32: 'A right is relative if it is not protected to the full extent of its scope. Justified limitations are thus placed on the right's full realization. Indeed, we can say that a right is relative whenever the extent of its protection is narrower than its entire scope'.

[91] Joined cases C-92/09 and C-93/09 Volker und Markus Schecke GbR and Hartmut Eifert v Land Hessen [2010] ECLI:EU:C: 2010:662.

[92] Recital 4 GDPR: "The right to the protection of personal data is not an absolute right; it must be considered in relation to its function in society and be balanced against other fundamental rights, in accordance with the principle of proportionality".

[93] Case C-582/14 *Breyer* [2016] ECLI:EU:C:2016:779, para 59.

[94] Case *Breyer* (n 93), para 46.

[95] Case *Breyer* (n 93), para 46 & Case C-582/14 *Breyer* [2016] ECLI:EU:C:2016:339 Opinion of AG CAMPOS SÁNCHEZ-BORDONA, para 68.

[96] In 'Standard Data Protection Model. A concept for inspection and consultation on the basis of unified protection goals', 33, the German federal DPAs relate the concepts of 'interference' and 'risk' as follows: *'In order to be able to evaluate the significance of the risks to the right to informational self-determination and which individual level of protection result from a procedure, the level of interference on the fundamental rights must be evaluated by means of a procedure'*.

[97] Article 52(1) CFR 'Any limitation on the exercise of the rights and freedoms recognised by this Charter must be provided for by law and respect the **essence** of those rights and freedoms. […]'.

[98] Barak A, Proportionality: Constitutional rights and their limitations, (Cambridge Studies in Constitutional Law) Cambridge University Press, 2012, doi:10.1017/CBO9781139035293, 497.

[99] Brkan M. (2018), 'The Concept of Essence of Fundamental Rights in the EU Legal Order: Peeling the Onion to its Core', *European Constitutional Law Review*, 14(2), 332-368. doi:10.1017/S1574019618000159, 346, Dawson M., The Governance of EU Fundamental Rights, Cambridge Studies in European Law and Policy, Cambridge University Press, 2017, doi:10.1017/9781107707436, 64.

[100] See for example Joined Cases C-293/12 and C-594/12 *Digital Rights Ireland* [2014], ECLI:EU:C:2014:238, paras 37, 39.

would lead to the 'non-existence of this right'.[101,102] When it comes to assessing whether an interference with the fundamental right to data protection has taken place and when evaluating the severity (classification) of this interference, the CJEU uses the proportionality test as methodological tool.

Coming to the concept of *risk*, it is a (type of) external intervention to a fundamental right, because it penetrates (even slightly) the penumbra of the fundamental right. In that sense, it is a concept that relates to 'interference' which could thus serve as a good starting point to understand *risk*. In his Opinion[103] on the Digital Rights Ireland case, AG Cruz Villalón indicated a relationship between the concepts *risk* and 'interference'. In paragraph 75 the AG suggests that '[t]he intensity of that interference is exacerbated by factors which increase the risk that […] the retained data might be used for unlawful purposes which are potentially detrimental to privacy or, more broadly, fraudulent or even malicious'. The factors that could increase the identified *risks* are taken into account and thus the AG uses the concept of *risk* as one of the criteria for assessing the severity of the interference that took place. The fact that the level of the interference is classified, *inter alia*, according to the level of risks, suggests that these two concepts have an analogical relationship; the higher the risks, the higher the interference. By unveiling the relationship between these two concepts we can gain useful insight as to *risk*. It goes without saying that the two concepts present differences that need to be taken into account. To give an example, *risk* is a hypothetical event[104] while an interference refers to an event that has already taken place. This means that interference is assessed and evaluated only in terms of severity, while the element of likelihood is of no relevance. Hence, the concept of 'interference' is useful in our analysis when it comes to evaluating the *severity* of a *risk* but not when it comes to its *likelihood*.

Second important source is the general European data protection legal framework whereby the concept of *risk* is introduced. The GDPR has its own concepts, tools, reasoning, purposes which should constitute the lens through which *risk*, *likelihood* and *severity* are examined and understood. The attributes that will be attached to the afore mentioned concepts should be framed within the EU data protection regime as defined by the law (GDPR) and as interpreted by the CJEU and the ECtHR. It is said that 'each provision of EU law must be interpreted in such a way as to guarantee that there is no conflict between it and the general scheme of which it is part'.[105] This points towards the need for a contextual interpretation of the provision which will enhance legal certainty through promoting consistency of EU law.

To be more precise, let us see an example of how contextual interpretation would prove insightful for the concept of *risk*. By taking a look at the way that other key concepts in the GDPR (e.g., 'personal data', 'data controller') have been legally qualified by the legislature and interpreted by the CJEU, we come to the following conclusion; the identification of the role that a concept holds in the data protection legal framework constitutes an important tool for the interpretation of the concept (at least) with regard to its scope (teleological interpretation).[106] *Risk* is a concept linked to the principle of accountability; accountability has been characterised as the 'fundamental principle of compliance';[107] thus *risk* is inextricably linked to compliance. It is linked to compliance in the sense that *risk* constitutes a major criterion that should be taken into account by controllers when adhering to legal obligations.[108] It is part of the modified compliance scheme[109] and the enhanced accountability principle that this scheme introduces in the GDPR.[110] Having in mind the role of *risk* in achieving an effective compliance with the data protection principles and therefore the essence of the right to data protection, it is fair to say that *risk* has been introduced in order to enhance the fundamental rights character of the GDPR.[111,112] This reaffirms the

[101] Brkan M. (2018), 'The Concept of Essence of Fundamental Rights in the EU Legal Order: Peeling the Onion to its Core', *European Constitutional Law Review*, 14(2), 332-368. doi:10.1017/S1574019618000159, 368.

[102] See also Ojanen T., (2016) 'Making the Essence of Fundamental Rights Real: The Court of Justice of the European Union Clarifies the Structure of Fundamental Rights under the Charter: ECJ 6 October 2015, C-362/14, Maximillian Schrems v Data Protection Commissioner' European Constitutional Law Review, 12(2), 318-329. doi:10.1017/S1574019616000225, 320: 'the judgment *[Schrems]* works out the constitutional structure of fundamental rights under the Charter by confirming at a level of a concrete court case what the limitations clause of Article 52.1 of the Charter expressly provides: fundamental rights contain an essence or inviolable core that be violated under any circumstance'.

[103] Joined Cases C-293/12 and C-594/12, Digital Rights Ireland [2013] ECLI:EU:C:2013:845, Opinion of AG CRUZ VILLALÓN.

[104] Article 29 Data Protection Working Party, 'Guidelines on Personal Data Breach Notification under Regulation 2016/679′ (Wp250rev.01), as last revised and adopted on 6 February 2018', 24.

[105] Lenaerts K and Gutiérrez-Fons JA, 'To Say What the Law of the EU Is : Methods of Interpretation and the European Court of Justice' (2013) EUI Working Papers AEL 2013/9 http://cadmus.eui.eu//handle/1814/28339, 14.

[106] For a more detailed analysis see, Demetzou K. (2019) GDPR and the Concept of *Risk*: In: Kosta E., Pierson J., Slamanig D., Fischer-Hübner S., Krenn S. (eds) Privacy and Identity Management. Fairness, Accountability, and Transparency in the Age of Big Data. Privacy and Identity 2018. IFIP Advances in Information and Communication Technology, vol 547. Springer, Cham and Demetzou K. (2019), 'Risk to the 'Rights and Freedoms' - A Legal Interpretation of the Scope of Risk Under the GDPR' (forthcoming).

[107] Alhadeff J., Van Alsenoy B., Dumortier J. (2012) The Accountability Principle in Data Protection Regulation: Origin, Development and Future Directions. In: Guagnin D., Hempel L., Ilten C., Kroener I., Neyland D., Postigo H. (eds) Managing Privacy through Accountability. Palgrave Macmillan, London https://doi.org/10.1057/9781137032225_4.

[108] See for example Article 24 'Taking into account the nature, scope, context and purposes of processing as well as the ***risks*** of varying likelihood and severity […]'.

[109] See previous Section, 2.1 "Article 5(2) GDPR: A general accountability principle".

[110] Demetzou K. (2019) GDPR and the Concept of *Risk*: In: Kosta E., Pierson J., Slamanig D., Fischer-Hübner S., Krenn S. (eds) Privacy and Identity Management. Fairness, Accountability, and Transparency in the Age of Big Data. Privacy and Identity 2018. IFIP Advances in Information and Communication Technology, vol 547. Springer, Cham.

[111] According to Article 1(2) GDPR 'This Regulation protects fundamental rights and freedoms of natural persons and in particular their right to the protection of personal data'.

[112] See, Demetzou K. (2019), 'Risk to the 'Rights and Freedoms' - A Legal Interpretation of the Scope of Risk Under the GDPR' (forthcoming).

broad scope that the legislature has given to *risk* (risk to the 'rights and freedoms' of natural persons). The identification of the role of *risk*, which is done by reference to the context of this concept (i.e., the principle of accountability, the modified compliance scheme, the objectives of the GDPR as explained in Article 1 etc.), is important for substantiating the stance adopted by the legislature for a broad scope of *risk* in the GDPR.

A third important source of objective legal criteria is the wording of the relevant Recitals and Articles of the GDPR as well as the guidelines provided by the EDPB and the national DPAs. By carefully looking into the examples given, we can infer the rationality behind them and extract common denominators that could be used as guidance when assessing processing operations that might not be included as examples in the law or in the published guidelines.

In a previous section[113] I categorized the examples of *risks* enumerated in Recital 75. The reason why such categorization is useful, is because it gives us the possibility to extract the criteria that the legislature uses in order to classify processing operations as *risky*. One should not only look at the *purpose, nature and scope of the processing* (second category) but also at the *damage* that the processing could result in (first category). The concept of *risk* is therefore linked to the concept of potential harm or damage to individuals.[114] That said, the fact that a company processes non sensitive personal data for purposes other than the evaluation of personal aspects (which means that the processing does not fall under the second category), does not mean that a risk of disclosure and consequentially a risk for identity theft (which falls under the first category) does not exist, and that the processing operations are not classified as risky. This categorization that we derive from the legislature's wording, provides us with two criteria that the legislature has used in order to give examples of risks that have to be taken into account when examining what could constitute a risk under data protection law; 'damages and unwanted events' and 'purpose, scope and nature of processing'. Had we not acknowledged that, and had we only relied on the second category *('purpose, scope and nature of processing'* which the legislature mentions in 35(1)) we would have conducted an incomplete risk assessment.

Each of the legal sources mentioned above provides us with important insight as to the elements that should qualify *risk* under the GDPR. The first legal source to turn towards is the EU fundamental rights framework. The EU Charter, heavily inspired by the ECHR, has gained the status of primary EU legislation and should serve as an aid to interpretation of EU secondary law.[115] The second legal source is secondary legislation, the GDPR, whereby the concept of *risk* is introduced. One first aspect to be examined is the general context within which *risk* is placed; more specifically, the compliance scheme and the enhanced accountability principle in the GDPR. The second crucial aspect of the secondary legislation to be examined are the provisions of the GDPR which are specific to *risk* but also the guidelines published by the national regulators as well as by the EDPB. These are interpretative documents that will shed light on a more objective understanding of *risk*.

This complementary approach is suggested as a way to address the shortcomings of the approach used in the GDPR (i.e., denotation of the concept of risk) and to address the gaps left from this approach for the qualification of *risk*. More specifically, it will enhance legal certainty which is a principle that could come in tension with the accountability principle and its functional elements (scalability, flexibility), as has already been highlighted by the WP29. At the same time, it will lay the foundations for enhancing objectivity in the risk assessment process, since the attributes are extracted from the context of the general EU data protection regime. In that way, the legal qualification of the notion of *risk* within the context of data protection and the effort to provide legal significance to its defining qualities (likelihood and severity) will contribute to a common understanding of these concepts and a common expectation of how this legal obligation should be met, providing for a solution to the scenarios described in Section 3.3 ('Legislature's guidelines').

4. Case study

In this Section, I will present a Case Study which will better illustrate two things; first, it will demonstrate the way in which the new obligation of performing DPIAs (Article 35) can fill in gaps that we have so far experienced in terms of protection of fundamental rights. Secondly it will clarify why such a legal obligation cannot unveil its potential in effectively protecting rights and freedoms unless the concept of *risk* is legally qualified and understood within the context of the general EU data protection regime.

Case Study: 'Better Together' (BeTo)[116] is an Online Social Network (OSN) targeting people who suffer from either minor or major emotional stress or went through difficulties that made them introvert and in search for comfort online. On its online platform, users have the possibility to create a profile with information about themselves and about their psychological status. They can generate and share content by posting their personal stories, they can join groups, but most importantly they can connect with other users. These users are called 'Companions'. Based on the users' profiles, activities and all the information provided and shared, BeTo recommends Companions to whom the users could better relate, discuss and ultimately feel better. Another possibility that this platform offers is what is called 'Today I feel'. This allows users to share a brief text everyday with their thoughts, their progress, things that made them feel better and share it with their Companions. Based on these updates BeTo creates a personalized yearly diary (called 'My yearly diary') which at the end of each year allows the user to see their progress with all relevant information. 'My yearly diary' is sent after request to each separate user who in turn can decide if they want to publish it and share it with their network or not.

BeTo has built an API for developers whereby third-parties can develop apps that users can download by signing in to

[113] Section 3.3 "Legislature's guidelines".

[114] ICO (n 72).

[115] Lenaerts, K. (2012). *Exploring the Limits of the EU Charter of Fundamental Rights*. European Constitutional Law Review, 8(3), 375-403. doi:10.1017/S1574019612000260, 376.

[116] This is a hypothetical name, used for the specific case study.

their BeTo account. When a user wants to install a third-party app, the app requests a set of permissions to access the user's profile information as well as the content shared by the user's Companions. Once the user has accepted the permissions, the app collects information that is stored on the 'App server'. BeTo's privacy settings by default allow access to the user's and the user's Companions' information. If the Companions do not wish their information to be shared with the app when a user installs it, they have to manually uncheck the relevant boxes in the default settings.

Researcher **'R'** has developed a personality quiz which is available to the BeTo users via an app (hereafter, the 'App'). **R** is interested in collecting information for academic research purposes. Through the App, **R** collects the answers given to the personality quiz, the personal data of those who installed the App as well as some personal data of their Companions. Most of this information is highly sensitive given that BeTo users share information about their psychological status, join groups according to their particular needs and in many cases also share their 'My Yearly Diary', which contains a range of statistical findings about their yearly progress, as compiled and calculated by BeTo.

One year after the App was available for downloading, a big number of BeTo users started receiving personalized offers on various medical drugs and therapies from a newly founded pharmaceutical company **'P'**. Later, it turned out that **R** had unlawfully shared with **P** all information that he had collected via the App. **R** had not only shared the information of those who had installed the app but also information of all their Companions. Based on the users' information (quiz answers and all other personal information that was shared), **R** and **P** inferred patient types, which they could later assign to all users (also the Companions). The ultimate goal was to create 'patient types' to frame as many BeTo users as possible (including those who had not downloaded the App) in order to target them with highly personalized advertisements about **P**'s products and therapies.

The processing of the App users' and their Companions' personal data by **R** and **P** took place in breach of BeTo's privacy policy. While **R** had obtained the App users' consent to process their personal data for research purposes, he did not have a legitimate basis for sharing them with **P**. On the other hand, **P** did not have a legitimate basis for processing this data for advertising purposes. Therefore, in the case of **R**, the processing of personal data of his App users was lawful, to the extent that the consent he obtained was valid (i.e., for the purpose of scientific research). Any processing of data of the Companions by either **R** or **P** was unlawful, and both the **R**'s sharing of user data with **P**, and the targeted advertising by **P** were unlawful.

Let us now turn to BeTo and examine its role as shaped under the GDPR, the proactive approach it establishes via the general accountability principle and the relevant DPIA obligation. BeTo is a data controller with regard to the personal data shared by its users on its online platform. It is an online platform with millions of users who share vast amounts of personal data, based on which detailed profiles are built. This attracts the interest of other (potentially malicious) actors to gain access to this data and use them for their own purposes.

In our case study, BeTo decided to initiate a new project, that is to build an API for third party app developers. The fact that personal data of BeTo users will be shared with third parties, constitutes a further processing of personal data. For that reason, and 'prior to the processing'[117] BeTo has to examine whether a DPIA has to be performed. As mentioned earlier on, BeTo shall first look into the guidance provided by the law so as to identify whether the planned data processing operations are likely to present *(high) risk(s)*.[118] The 'scope' of processing *(vast amounts of personal data)* as well as the 'nature' of the processing *(which is done on sensitive data – psychological status, information about therapies that users follow and share, 'My yearly diary' information etc.)*, are criteria that the EU legislature qualifies as indicators of risk (art. 35(1)). On top of that, Article 35(3) requires that a DPIA is performed in the case of '*(b) processing on a large scale of special categories of data referred to in Article 9(1)'*, indicating that this is considered to be a 'high risk'.

Following the legislature's guidelines, both the scope and the nature of the new processing operations are 'likely to result in high risks to the rights and freedoms of natural persons'. This 'high-level screening test' indicates that there is a 'reasonable chance' that BeTo's new project will present high risks. For that, BeTo has to act proactively and perform a DPIA, which entails the identification of risks, their assessment in terms of likelihood and severity and their management. That means that BeTo will go into the heart of the process and will have to actually measure the risks in order to make decisions as to their acceptability, as to the measures they should take in order to manage the risks and as to the need of consulting with the DPA (according to Art 36).

To begin with, possible risks should be identified. My intention is not to enumerate all the possible risks that BeTo's new project might raise. It is rather to accentuate the argument made in a previous Section,[119] that the legislature's guidelines are not comprehensive in terms of what qualifies as *risk* under the GDPR and therefore recourse should be found in additional legal sources.

(1) A first risk is raised by the existing privacy policy in combination with the new processing operations that will take place because of the building up of the API. This risk is mentioned in Recital 75 and it is the *unwanted result* of preventing data subjects 'from exercising control over their personal data'. This is particularly relevant in this case for the Companions, whose data are shared with the App developer when a user downloads the App. According to BeTo's privacy policy third-party apps may have access to the users' and their Companions' information, unless the latter have manually changed the default settings. Users who have installed the App have provided their consent for their personal data to be shared with the app for the specific purpose of taking the personality quiz. However, when it comes

[117] According to Art. 35(1) GDPR.

[118] This constitutes the 'high-level screening test' (otherwise termed, the threshold analysis) discussed in Section 3.3, whereby the data controller looks for 'red flags' that signal potential high risks.

[119] See Section 3.3 "Legislature's guidelines".

to the Companions, they have no knowledge that their personal data will be processed by this App and have not provided their consent which leads to them not having any substantial control over their personal data. This is a phenomenon that has been termed as *'interdependent privacy'*.[120] Therefore, and specifically for the case of Companions, BeTo's new project raises a risk to 'interdependent privacy' via 'collateral information collection'.[121]

The identification of the risk to 'interdependent privacy' which in this specific case takes the form of data subjects being prevented from exercising control over their personal data,[122] does not follow straightforwardly from the legislature's guidance. It is a risk which, although it does not refer to a new right (the right to privacy is not new), it does refer to a new dimension of the traditional right to privacy ('interdependent privacy'). This new dimension is a consequence of the new technologies involved in data processing operations.[123] When it comes to assessing this specific risk, BeTo has no tools or criteria to measure it. However, as argued above,[124] useful conclusions can be drawn if we closely examine the theory on the structure of fundamental rights. According to Brkan,[125] a *de iure* denial of a right or the *de facto* unfeasibility to exercise a right, both amount to a breach of essence of the fundamental right in question. A breach of essence leads to the non-existence of the fundamental right, and for that, it is highly severe and not permissible/legally justifiable.[126] Having that in mind, one could argue that the risk to 'interdependent privacy' that has been identified, should qualify as 'high' -at least- in terms of severity. This is because in case this risk materializes, Companions will be deprived of their right to privacy.

(2) A second risk is raised by the context of the processing operations under examination which is sharing sensitive personal data of BeTo users with third party app providers. Given that everybody who wants to develop an app using BeTo's API has the possibility to do so, and given that BeTo is not reviewing all apps in terms of privacy policy or security, there is a risk of unlawful use of users' personal data. One scenario is that one third party app provider is the owner of multiple apps on BeTo's platform. This third party can cluster these apps, collect all relevant personal data shared via these apps and by retrieving the user BeTo ID that uniquely identifies each user, create a full profile of the users.[127] Another scenario is the combination of personal data collected via the App with background information held by the third party app provider (or by another party). This leads to the linking of two datasets and the identification of data subjects for other purposes[128] (e.g., targeted advertising, micro-targeting etc.). Imagine the case where the third party app provider has access to patient registries or that they share the accessed personal data with another party that has access to patient registries; or the case where the third party app provider is an insurance company which can combine data obtained from the App with its customers' registries. This raises additional risks for the rights and freedoms of data subjects but also risks for our society as a whole.

In the case of this second risk, it is crucial that BeTo does not limit itself in identifying only the 'risk of unlawful use' of personal data. Rather, BeTo has to acknowledge the broad scope that has been attributed to the concept of *risk* under the GDPR. This broad scope follows from the legislature's wording in Art 35 ('*risk to the rights and freedoms of natural persons*') but is firmly substantiated by the role of *risk* in the GDPR. The role that *risk* plays is part of the contextual interpretation of the concept, as explained earlier on, in a previous Section.[129] In our example, BeTo has to take account of this broad scope (both in terms of 'rights and freedoms' affected but also in terms of 'natural persons' affected) and identify risks which might be raised in case the 'unlawful use of personal data' takes place.

The importance of having in place the DPIA obligation is apparent from this case-study. The case study clearly demonstrates that if BeTo had performed a DPIA on this new

[120] Gergely Biczók and Pern Hui Chia, 'Interdependent Privacy: Let Me Share Your Data' in Ahmad-Reza Sadeghi (ed), *Financial Cryptography and Data Security* (Springer Berlin Heidelberg 2013). The authors have defined "interdependent privacy" as the phenomenon whereby *"the privacy of individual users is bound to be affected by the decisions of others, and could be out of their control. […] the protection of personal, relational and spatial privacy of individuals is increasingly dependent on the actions of others, rather than the individuals themselves, in the interconnected digital world."* In their paper, the authors have discussed this phenomenon in relation to the Facebook application platform and its permission system.

[121] Symeonidis et al, (2016) 'Collateral Damage of Facebook Apps: Friends, Providers, and Privacy Interdependence' In: Hoepman JH., Katzenbeisser S. (eds) ICT Systems Security and Privacy Protection. SEC 2016. IFIP Advances in Information and Communication Technology, vol 471. Springer, Cham.

[122] This is explicitly mentioned in Recital 75 GDPR '[…] where data subjects might be deprived of their rights and freedoms or prevented from exercising control over their personal data'.

[123] Demetzou K. (2019) GDPR and the Concept of *Risk*: In: Kosta E., Pierson J., Slamanig D., Fischer-Hübner S., Krenn S. (eds) Privacy and Identity Management. Fairness, Accountability, and Transparency in the Age of Big Data. Privacy and Identity 2018. IFIP Advances in Information and Communication Technology, vol 547. Springer, Cham, 149.

[124] See Section 3.5 "An additional approach to qualifying *risk*".

[125] Brkan, M, In Search of the Concept of Essence of EU Fundamental Rights Through the Prism of Data Privacy (January 16, 2017). Maastricht Faculty of Law Working Paper No. 2017-01, 13. Available at SSRN: https://ssrn.com/abstract=2900281 or http://dx.doi.org/10.2139/ssrn.2900281.

[126] Brkan M. (2018), 'The Concept of Essence of Fundamental Rights in the EU Legal Order: Peeling the Onion to its Core', *European Constitutional Law Review*, 14(2), 332-368. doi:10.1017/S1574019618000159, 350, 356.

[127] This scenario has been discussed in the case of Facebook Apps in the work of Symeonidis et al (n 121). In this work, the authors have described the phenomenon of "[…] appPs offering multiple apps thereby enabling user profiling", as one case of "collateral damage".

[128] This is a case discussed by the Article 29 Working Party, 'Opinion 05/2014 on Anonymisation Techniques', 34.

[129] See Section 3.5 "An additional approach to qualifying *risk*".

project, they could have identified the risks that eventually materialized. If BeTo had a legal obligation to conduct a DPIA, they would have identified that the sharing of sensitive information with a third party presents high risks to the rights and freedoms of the users and their companions. They would have managed these risks appropriately – even if that meant not sharing this data at all, not even for research purposes. Identification of the risks is the first step in the DPIA process, the others being assessment of likelihood and severity and lastly mitigation of the high risks.

This example shows that whereas the previous data protection regime (under the DPD) may have led to poor compliance, the prominence of the GDPR's proactive approach has the potential to provide for a more effective data protection. In our case, two other data controllers (**R** and **P**) conducted unlawful processing of BeTo users' and their companions' personal data. Though **R** and **P** are not data processors (in which case BeTo would have been responsible for their unlawful conduct), BeTo will still be held responsible for not having correctly assessed and mitigated the risks before embarking on the project of building its API, due to the obligation to conduct a DPIA under the GDPR. The risks that should have been identified and mitigated, eventually materialized: *companions* were deprived of any substantial control over their personal data, and the users' personal data were eventually processed for purposes they had no knowledge of and for which they had not provided their consent.

DPIA has filled a gap in the legal protection of personal data and affected fundamental rights and freedoms, by obliging the data controller to act proactively and to scrutinize all processing operations they initiate. In case where the data controller has not correctly performed the DPIA they will be held accountable and responsible for not having correctly identified and mitigated the high risks to the rights and freedoms.

5. Conclusion

In this article I discussed the novel legal obligation of performing a DPIA under Art 35 GDPR. More specifically, I examined the way in which this legal obligation contributes to a more effective and high level of data protection. In Section 2 the reinforced general accountability principle is described as a major change of approach in the revision of EU data protection law. The GDPR introduces a reconfigured and reinforced mechanism for compliance. This mechanism entails scalable obligations, a prominent example of which is the performance of DPIAs in cases where processing operations present "high risks to the rights and freedoms of natural persons". The importance of this new legal obligation lies in its inclusive, comprehensive and proactive nature.

In Section 3, I investigated the requirement of 'high risk' which is constitutive of the obligation to perform a DPIA. Under the DPIA, data controllers have to identify what could constitute a risk in the field of data protection and then, assess the identified risk in terms of likelihood (how likely is it that the risk will materialize?) and in terms of severity (how severe will this risk be for the rights and freedoms of natural persons if it eventually materializes?) *(triple assessment)*. This assessment should be performed in an objective way *(objective triple assessment)*. Despite its importance, the concept of *high risk* is not legally qualified under the GDPR. The legislature provides examples of *risky* and of *highly risky* processing operations which serve as a guidance for the data controller at the level of the so-called 'threshold analysis' (high-level screening test). This article argues that the guidelines given by the legislature are not enough for a data controller to be able to objectively assess and measure risks when they actually perform a DPIA. A complementary approach to qualifying *risk* under the GDPR should thus be adopted. The EU fundamental rights framework, the GDPR itself and the guidelines published by the EDPB and by the national regulators, should all constitute the legal sources that will provide us with necessary features of *risk* and with the appropriate tools in order to be able to identify such features. Failure to achieve a proper understanding of the concept of *high risk*, will hamper the function of the DPIA as a tool for more effective data protection. If data controllers do not have a clear understanding of the notion of risk, they may be tempted to ignore the need to perform a DPIA. This would mean that high risks are not identified and appropriate mitigation measures will not be applied.

In the last section (Section 4) of the article, I demonstrated the importance of this new legal obligation by way of a Case Study. The DPIA forces data controllers to seriously consider and mitigate high risks to the rights and freedoms of natural persons and the GDPR considers them responsible when they fail to correctly apply the DPIA mechanism. I also demonstrated that without a clear understanding of *risk* within the context of the general EU data protection regime, the value of the DPIA in protecting rights and freedoms will be seriously undermined.